Justificativa Técnica

1. Por que cada componente foi incluído

Componente	Por que está aqui
VPC	Cria um espaço de rede, onde nós decidimos o que é público.
Sub-redes em duas zonas	Separam entrada, aplicação e dados, e mantêm o sistema no ar se uma zona falhar.
Internet Gateway	Porta de ligação entre a nossa rede e a internet.
WAF	Barra ataques comuns (como injeção de SQL) antes de chegarem na aplicação.
ALB	Ponto de entrada: recebe o HTTPS e distribui as requisições entre os servidores.
EC2 (API)	Executa a lógica da aplicação e fica protegida em sub-rede privada.
RDS Multi-AZ	Guarda os dados e mantém uma cópia em outra zona, que assume se a principal falhar.
S3	Serviço para guardar os arquivos dos usuários, com acesso controlado.
VPC Endpoints	Criam um caminho privado até S3 e Secrets Manager, sem passar pela internet.
Secrets Manager	Guarda a senha do banco fora do código.
NAT Gateway	Deixa os servidores privados saírem para atualizar, sem aceitar entrada.
Client VPN + MFA	Dá à equipe um caminho seguro, sem abrir portas para a internet.
Security Groups	Definem quem pode falar com quem e em qual porta.
IAM	Controla o que cada pessoa e serviço pode fazer.

Componente	Por que está aqui
CloudTrail, Flow Logs e CloudWatch	Registram e alertam sobre o que acontece, para auditoria.

2. Por que determinados recursos estão em sub-redes públicas ou privadas

só fica público o que precisa ser alcançado diretamente pela internet.

- **Subnet Pública (ALB e NAT):** O ALB precisa receber os clientes e o NAT precisa de saída pelo Internet Gateway. Nenhum servidor de aplicação e nenhum banco ficam aqui.
- **Subnet Privada da aplicação (EC2):** A API só precisa ser chamada pelo ALB. Sem IP público, mesmo quem encontrar o endereço não consegue chegar nela.
- **Subnet Privada de dados (RDS):** O banco só conversa com a API e não tem rota para a internet. Se um servidor da API for invadido, o banco ainda está atrás de outro controle.

3. Quais conexões são permitidas e quais são bloqueadas

Os Security Groups são encadeados, a internet fala com o ALB, o ALB fala com a API, a API fala com o banco, e só. Como esses grupos só possuem regras de permissão, tudo que não foi liberado é negado.

Permitido: Cliente para o ALB (443), ALB para a API (8080), API para o banco (5432), API para S3 e Secrets Manager (443, pelos endpoints), API para a internet via NAT (443), administrador para a VPN (443 + MFA) e VPN para a API (SSH 22).

Bloqueado: Internet para a API, para o banco, para o SSH e para o S3.

4. Como o acesso administrativo é protegido

- **Nenhuma porta de administração aberta para a internet.** O SSH só é alcançável por quem já está dentro da VPN.
- **MFA na entrada.** O administrador comprova quem é com senha e um segundo fator.
- **Caminho curto.** O SG-VPN só consegue chegar à porta 22 dos servidores da aplicação e não alcança o banco diretamente.
- **Rastreabilidade.** As ações de API ficam no CloudTrail e o tráfego nos Flow Logs.

5. Como as permissões de serviços e usuários são limitadas

Seguindo o menor privilégio, onde cada um recebe só o que precisa para trabalhar.

- **EC2:** Usa uma role do IAM, com credenciais temporárias que se renovam sozinhas. Não existem chaves de acesso escritas no código.
- **Acesso ao S3 e ao segredo do banco:** A role permite apenas o necessário (ler e gravar arquivos no bucket da aplicação e ler a senha do banco).

- **Administradores:** MFA obrigatório.
- **Banco de dados:** Só aceita as conexões do grupo de segurança da aplicação.

6. Como a arquitetura reduz riscos de exposição de dados e de acesso não autorizado

Exposição de dados

- API e banco não têm caminho direto a partir da internet.
- O bucket S3 não é público e só aceita acesso pelo endpoint da VPC.
- A senha do banco fica no Secrets Manager.
- O tráfego do cliente usa HTTPS.

Acesso não autorizado

- O WAF barra ataques comuns na borda.
- Security Groups encadeados limitam o alcance de invasores.
- O acesso administrativo exige VPN e MFA.
- O menor privilégio reduz o estrago se uma conta ou serviço for comprometido.

Se um servidor EC2 for comprometido, o invasor continua limitado ao que a role e os Security Groups permitem. Assim reduzindo o impacto, mas não eliminando o risco. Por isso o monitoramento faz parte do projeto.

7. Como os registros de auditoria ajudam a identificar atividades suspeitas

Registro	O que mostra	Exemplo de sinal de alerta
CloudTrail	Quem fez cada chamada de API	Alteração em Security Group ou login sem MFA
VPC Flow Logs	Tráfego aceito e rejeitado	Muitas rejeições do mesmo IP ou tentativas nas portas 22 e 5432
CloudWatch	Reúne os logs e dispara alarmes	Alarme avisando toda a equipe

Eles se complementam: o Flow Logs mostra a *tentativa de conexão*, enquanto o CloudTrail mostra quem mexeu na configuração.

8. VPN e VPC Endpoint: qual problema cada um resolve

Mecanismo	Problema	Solução e por que é adequado
Client VPN	A equipe precisa chegar aos servidores privados sem expor a porta 22 à internet.	A VPN com MFA cria um túnel autenticado e o SG-VPN limita o alcance ao SSH da aplicação.

Mecanismo	Problema	Solução e por que é adequado
VPC Endpoints (S3 e Secrets Manager)	Os servidores estão em sub-rede privada e esses serviços ficam fora da VPC. Sem endpoint, o tráfego iria pela internet.	O endpoint cria um caminho privado dentro da AWS e permite que o S3 aceite só acessos da VPC.
NAT Gateway	Os servidores precisam baixar atualizações, mas não podem ser alcançáveis de fora.	Permite a saída e bloqueia conexões iniciadas de fora. Um por zona, para não haver ponto único de falha.

9. Decisões de projeto e compensações

- **HTTP entre ALB e EC2:** O HTTPS termina no ALB e o trecho interno (porta 8080) usa HTTP, o que significa que esse trecho não é criptografado. Compensamos mantendo dentro da VPC e sendo protegido por Security Group, que só aceita tráfego do ALB. Uma alternativa seria usar HTTPS ponta a ponta.
- **Custo de resiliência:** Adotamos um NAT por zona e o RDS Multi-AZ, que têm custo fixo por hora. Compensamos com mais disponibilidade, onde se uma zona falhar, a outra continua com saída para a internet e com uma cópia do banco.
- **Acesso por VPN:** A Client VPN dá acesso à rede de forma mais ampla do que um acesso pontual. Compensamos com o SG-VPN restrito (só alcança a porta 22 dos servidores da aplicação), MFA obrigatório e registro dos eventos.